MVP Build Plan — Three-Tier Architecture (Phase 1)

Community-Governed Data for Nonprofit Accountability

A build plan for a three-tier network architecture (presentation → application → data) with stored data, derived from the **Data-Hosting Decision** memo. It assumes **synthetic data only** through the residency and a stack that stays **portable** so it can re-home to a community-controlled host or data trust later, exactly as the memo recommends. The 8-week schedule is deliberately aggressive for one part-time person — Week 8 is a buffer, and the guardrails below say what to cut when a week slips (scope, never the safety rails).

1. Core build strategy & system design

Three tiers, all on free resources, all portable by design. The data tier holds the stored record (Postgres plus S3-compatible object storage for audio/video). Nothing proprietary, so the whole stack lifts and shifts when the project is resourced.

Tier	Infrastructure stack (free resources)	Solo developer strategy
Tier 1 — Presentation (resident / web client)	• Next.js or SvelteKit, containerized with Docker • GitHub public repo under AGPL (free for open source) • Deploy on Fly.io free allowance, or an Oracle Cloud Always Free VM running Coolify / Dokploy (open-source PaaS) • Cloudflare free tier for DNS, TLS, and CDN	• Keep it framework-neutral and Dockerized so it re-homes to any host later • Mobile-first, low-literacy, offline-capable capture for residents • Every community-owned value is config, labeled “provisional — not set by the community” • Ship unfinished work behind feature flags; synthetic data only

Tier	Infrastructure stack (free resources)	Solo developer strategy
Tier 2 — Application (API & business logic)	• FastAPI (Python) or Node/Express in a Docker container, same VM / PaaS • REST/JSON API; secrets as environment variables • GitHub Actions free CI (lint, test, build)	• One modular service; externalize metrics, thresholds, quorum, retention as config, never constants • Role-based access, default most-restrictive; the provider can never read raw individual accounts • Do anonymization / aggregation here, with configurable thresholds • Build NO org-run body selection (guardrail); issuance and revocation are explicit community actions
Tier 3 — Data (stored data)	• Postgres via Supabase or Neon free tier (open-source, self-hostable core), or self-hosted Postgres in Docker • S3-compatible object storage for audio/video: Cloudflare R2 free tier or self-hosted MinIO • Schema and migrations in code (Prisma / Alembic)	• Synthetic / seed data only until the Tier-1 community decisions are ratified (a no-go gate) • Data community-owned and deletable from the first byte; minimal schema, every extra field opt-in • Encrypt at rest and in transit; keep raw inputs (no one-way aggregation) • Portable by design (Postgres + S3-compatible, no proprietary APIs) so it moves to a community-controlled host or data trust later

2. Schedule for the 8-week MVP sprint

The order follows the dependency chain in the backlog: foundations first, then safety and consent, then the record and the gap, then the body, the warrant, the provider, and funding discipline — with a hardening-and-demo buffer at the end. Everything runs on synthetic data.

Week	Focus	Key deliverables	Done when
Week 1	Foundations & three-tier skeleton	AGPL repo; Docker Compose running all three tiers; Postgres + object storage seeded with synthetic data; CI; deploy pipeline to a free host; externalized-config scaffold	“docker compose up” runs the full stack locally and deploys to the free host; a synthetic record round-trips through all three tiers; config values are externalized and labeled provisional

Week	Focus	Key deliverables	Done when
Week 2	Security baseline + consent / anonymity	Encryption at rest/in transit; privacy by design; anonymous submission flow; configurable aggregation thresholds; consent model drafted (design only); breach-response plan drafted	Contributions carry no identifying data by default and cannot be traced to an individual (synthetic test); consent model written for review; no real-data path exists
Week 3	Resident capture & the record	Multi-format capture (audio, video, text); resident view / correct / export / delete of own data	A resident can submit in all three formats and fully export and delete their own data (synthetic); accounts stored in the community-owned store
Week 4	Official-record ingestion & the gap	Ingest sample official records; documented cross-check method; gap computation and display with no pass/fail threshold	The system shows the reported-vs-lived gap on sample data; the cross-check method is documented with its limits stated; raw inputs retained
Week 5	The independent community body	Self-organized membership via neutral sign-up (no org selection); configurable quorum; community-controlled access rules; independence re-check workflow	A body can be stood up with no org-run selection; access defaults to most-restrictive and the provider sees no raw accounts; quorum is configurable
Week 6	The warrant	Warrant issuance as an explicit community action; one-step low-friction revocation; public warrant register; retaliation safeguard hook	The community can issue and revoke a warrant on synthetic data with no automatic or score-triggered issuance; revocation tested end-to-end; register published
Week 7	Provider onboarding & funding discipline	Provider record intake; minimal outcome stub (housed / stayed-housed); provider credential view; public conflict register; funder-cap tracking	A provider can open a sample record and see its community-issued standing; the conflict register is live; the cap-breach flag works
Week 8	Integration, demo & hardening (buffer)	End-to-end primary loop on synthetic data; tabletop revocation test; exit-criteria self-check; how-to / standard written; slack for slippage	The full primary loop turns end-to-end on synthetic data; the release exit criteria are reviewed; the how-to lets a successor run it; no won't-build shipped

3. Guardrails for a team of one

A solo build fails in predictable ways — scope creep, a stack that traps you, burnout, and the quiet temptation to touch real data before it is safe. These guardrails are the definition of done and the risk rules that keep the eight weeks honest.

Definition of done

Per item — nothing is "done" until all of these hold:

- It runs locally via "docker compose up" on synthetic or seed data — no real resident data, ever, this phase.
- Every community-owned value is externalized config and labeled "provisional — not set by the community"; nothing is hardcoded.
- CI is green (lint + tests); anything unfinished is behind a feature flag.
- No won't-build is introduced; the provider cannot read raw accounts; there is no org-run body selection.
- It traces up to a scope item and an epic — no orphan work.
- The repo how-to is updated so a successor could run it.

Per release — the gate to "MVP done" is the release exit criteria: warrant integrity (an independent body issues and revokes), zero privacy breaches and zero retaliation in testing, and the primary loop turning end-to-end — with none of the seven won't-builds present.

Risk management

- **Single-operator dependency (bus factor).** Open-source from day one, write the how-to as you build, and keep everything in Docker Compose + infrastructure-as-code so a successor can run it. The fix is to not stay the owner.
- **Scope creep.** Build only MVP #1's P0 problems plus the funding discipline; defer the secondary audiences; keep work-in-progress to one or two items; drive from the Now / Next / Later backlog.
- **Synthetic-data discipline.** Real data is a no-go gate — enforce it in code (no real-data path exists) until the Tier-1 community decisions and the consent model are ratified.
- **Vendor lock-in.** Postgres + S3-compatible storage + standard auth only; no proprietary vendor APIs, so the stack re-homes to a community-controlled host later.
- **Time & burnout.** Protect a bounded, realistic weekly slice from the enterprise product; Week 8 is a buffer. If a week slips, cut scope — never the safety rails (consent, anonymity, warrant integrity).
- **Unfilled legal / security roles.** Do not collect real data; line up pro-bono counsel and an outside security / ethics review as a parallel ask; keep these as no-go gates, not afterthoughts.
- **Weekly checkpoint.** Each week, review progress against the exit criteria and the kill / no-go list. A slipped week trims data-tier or secondary-audience scope, never the primary-loop safety rails.

4. Fallback: the minimum viable demo (MVD)

If the weekly hours don't hold, this is the thinnest build that still proves the primary loop turns — on synthetic data, end to end. It shows the idea works; it does not try to be the MMP. Decide at the **Week 4 checkpoint**, not Week 8: if the record-and-gap tier isn't working end to end by then, switch to this track and spend Weeks 5–8 wiring the thin loop and the demo rather than the full body / provider / funding build.

What the MVD must still prove (the irreducible loop): a resident contributes safely (anonymously) → the record and the gap are visible → the community body issues a warrant as an explicit action → the warrant can be revoked → the provider's standing changes — all on synthetic data, in a scripted walkthrough.

Kept in scope

- Text-only anonymous contribution (anonymity by default stays).
- A pre-loaded sample record with the gap already computed and shown (not freshly cross-checked).
- Explicit community action to issue and revoke a warrant (never automatic or score-triggered).
- A simple public warrant register (who holds it, since when).
- The three-tier skeleton on free hosting, synthetic data only.

Cut or faked (defer to the full build)

- Audio and video capture → text only.
- Live official-record ingestion and cross-check → a hardcoded sample gap.
- Full community-body tooling (self-organized sign-up, configurable quorum, independence re-check) → a single stubbed body with a documented, provisional rule.
- Provider onboarding, record intake, and the outcome stub → a static sample provider.
- Funding-discipline UI (conflict register, cap tracking) → documented as policy, not built.
- Resident export / delete, offline and mobile polish, retaliation hook.

Still non-negotiable, even here: anonymity by default; issuance and revocation are explicit community actions; synthetic data only, with no real-data path in the code; none of the seven won't-builds; and the loop visibly turns.

Definition of done (MVD): the primary loop turns end to end in a scripted demo on synthetic data — an anonymous contribution, a visible gap, an explicitly issued warrant, and an explicit revocation that changes the provider's standing — with anonymity intact and no won't-build present. Everything cut here moves back onto the Now / Next / Later backlog as post-residency work.